



PDF Download
3685651.3685657.pdf
26 February 2026
Total Citations: 3
Total Downloads: 496

 Latest updates: <https://dl.acm.org/doi/10.1145/3685651.3685657>

RESEARCH-ARTICLE

Privacy-Friendly Sharing of Health Data Using a Reference Architecture for Health Data Spaces

AMIR SHAYAN AHMADIAN, University of Koblenz, Koblenz am Rhein, Rheinland-Pfalz, Germany

SEBASTIAN FRANKE, University of Koblenz, Koblenz am Rhein, Rheinland-Pfalz, Germany

CHARLY GNOGUEM, University of Koblenz, Koblenz am Rhein, Rheinland-Pfalz, Germany

JAN JUERJENS, University of Koblenz, Koblenz am Rhein, Rheinland-Pfalz, Germany

Open Access Support provided by:

University of Koblenz

Published: 22 October 2024

Citation in BibTeX format

eSAAM 2024: 4th Eclipse Security, AI, Architecture and Modelling Conference on Data Space
October 22, 2024
Mainz, Germany

Privacy-Friendly Sharing of Health Data Using a Reference Architecture for Health Data Spaces

Amir Shayan Ahmadian
University of Koblenz
Germany
ahmadian@uni-koblenz.de

Charly N. Gnoguem
University of Koblenz
Germany
gnoguem@uni-koblenz.de

Sebastian Franke
University of Koblenz
Germany
sfranke@uni-koblenz.de

Jan Jürjens
University of Koblenz
Fraunhofer ISST
Germany
http://jan.jurjens.de

Abstract

Information systems are increasingly utilizing data to provide various services. However, failure to properly protect data may affect data subjects negatively, and damage the reputation of service providers. This work aims to establish a privacy-friendly data space that enables safeguarded sharing of health data¹ among various stakeholders in health domains. We propose a comprehensive reference architecture that integrates security/privacy mechanisms to uphold security and privacy requirements of health data and ensure strict adherence to demanding mandates. Furthermore, this article puts forth a blueprint for contracts when sharing data to cultivate transparency among various parties by harmonizing legal, technical and operational facets. This blueprint significantly reduces uncertainties and fosters an environment of trust. Our twofold methodology enables entities of a health data space to share health data, while upholding the security and privacy principles. The Eclipse Data Space Connector (EDC) is used as the basis to implement the proposed architecture.

CCS Concepts

• **Security and privacy** → **Domain-specific security and privacy architectures.**

Keywords

Health data spaces, Privacy-aware architecture, IDS RAM

ACM Reference Format:

Amir Shayan Ahmadian, Sebastian Franke, Charly N. Gnoguem, and Jan Jürjens. 2024. Privacy-Friendly Sharing of Health Data Using a Reference Architecture for Health Data Spaces. In *4th Eclipse Security, AI, Architecture*

¹Health data refers to personal electronic health data definition applied by [29] and means data concerning health and genetic data as defined by the General Data Protection Regulation [28], as well as data referring to determinants of health, or data processed in relation to the provision of healthcare services, processed in an electronic form.

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for third-party components of this work must be honored. For all other uses, contact the owner/author(s).
eSAAM 2024, October 22, 2024, Mainz, Germany
© 2024 Copyright held by the owner/author(s).
ACM ISBN 979-8-4007-0984-5/24/10
<https://doi.org/10.1145/3685651.3685657>

and Modelling Conference on Data Space (eSAAM 2024), October 22, 2024, Mainz, Germany. ACM, New York, NY, USA, 10 pages. <https://doi.org/10.1145/3685651.3685657>

1 Introduction

IT systems are increasingly harnessing the power of artificial intelligence, ushering in new possibilities such as value-added services for customers and substantial enhancements in organizational productivity and efficiency. Data processing and data sharing are at the heart of many AI systems. Organisations can lower costs and improve their services by sharing data. However, relying more and more on complex systems that offer data processing and data sharing in critical domains such as healthcare can cause huge problems. The number and severity of attacks on AI systems are rising [25].

The Covid pandemic has shown that data processing is critical to create appropriate responses to developments during pandemics [17]. By knowing where and when people are infected, the spread of a disease can be estimated to react in time. However, this kind of data is very sensitive. Appropriate mechanisms and concepts are required, whenever health data is shared [28].

Organisations need to be careful about the terms of data sharing as well. The concept of data spaces has emerged to allow data sovereignty while enabling data sharing. Organisations can set policies and reflect them in contracts that introduce rules on data sharing and data storage.

The International Data Spaces (IDS) offers the IDS Reference Architecture Model (IDS RAM) for data spaces [1]. IDS RAM serves as a blueprint and provides exemplar of design principles to ensure trustworthiness in data exchange and data sovereignty in the economy of the future². However, specific data spaces, such as a health data space, have not received much attention. Additionally, despite the promises of economic benefits, especially in aggregating data for research and public health planning, health data spaces face critical challenges in addressing privacy concerns [18].

In spite of the current implementations of the IDS RAM, the reference architecture, while a highly conceptual model, falls short in shedding light on crucial details such as the nature and structure of privacy policies governing data sharing within data spaces and the provenance of the data. Investigating the nature and the structure of contracts that provide clarity and transparency, allowing

²<https://internationaldataspaces.org>

stakeholders to understand the terms and conditions that govern sharing within data spaces is crucial.

In this paper, we introduce a reference architecture that focuses on health data sharing in a data space. We further focus on the contracts that specify how the shared data can be processed.

We investigate the following research questions:

- RQ₁* How can a data sharing contract be designed for data spaces to specify privacy and security requirements?
- RQ₂* How can the IDS RAM be adapted to realize a privacy-friendly sensitive data sharing in health data spaces?

Our contribution addresses three aspects:

- C₁* A contract structure for data spaces in section 4, bolstered by our proposed domain-specific ontology. It addresses privacy and security requirements and enables precise articulation of commitments such as the General Data Protection Regulation (GDPR) rights and the European Health Data Space Regulation (EHDS) rights.
- C₂* Adapting the IDS RAM to allow health data sharing. We introduce data subjects as an active role in the architecture (Section 5).
- C₃* We introduce an example of the architecture based on the Eclipse Data space connector (EDC) (Section 6.3).

A contract establishes legal agreements and obligations governing the processing of data among various parties. A well-structured contract provides clarity, minimizes disputes, and ensures all parties understand their rights, responsibilities, and expectations within health data spaces. We propose a structure for contract offers that captures the key properties required from a contract. First, an ontology is defined for contracts. We focus on privacy and security aspects to allow the definition of privacy and security requirements and mechanisms such as anonymization.

The IDS RAM is a virtual data space to facilitate secure data exchange in a trusted ecosystem. We extend the existing roles to address data subject requirements (the right to be informed and control their data). We specify that anonymization should be a central part of the transfer pipeline before data is being sent. Furthermore, data subjects have to be able to remove their data without much effort and to be informed about what is happening with their data [28]. We introduce a use case, in which such data can be shared in the context of a research project.

The remainder of this paper is organized as follows. In Section 2, we discuss related work. In Section 3, we briefly introduce the IDS RAM. In Section 4, we introduce the structure of contracts based on an ontology. In Section 5, we introduce our reference architecture. In Section 6, we evaluate our results. In Section 7, we conclude.

2 Related work and state of the art

Existing endeavors such as the IDS Usage Contract Language elaborated in [15], and the policy expression technique detailed in [27], as well as the ODRL language [14] and its ontology primarily concentrate on articulating usage control rather than the foundational structure of agreements. While the reference architecture for data spaces [1] acknowledges the significance of data sharing agreements, it remains silent on their structural attributes. Moreover, the architecture incorporates robust security mechanisms. However,

a comprehensive integration of these mechanisms within the proposed agreement structure was yet to be addressed which motivated our contribution towards a structured contract offer.

There are several guidelines and standards to establish agreements on data sharing such as [5, 8]. We leverage such documents to establish our contract structure. However, these only provide a basis or guideline to build such a contract and particularly in case of health data several other legal principles have to be considered.

Our architecture is largely inspired by the IDS RAM [1]. The Gaia-X project aims to build many data spaces tailored for specific field of operations, with coherent key functions. The Health-X data space aims for similar results as our architecture [16]. Their architecture is more focused on establishing a centralized institution that has control over the anonymization and that acts as a singular broker and certification authority. Our approach enables a less centralized approach, as many groups can create their own separate data spaces, if they do not wish to engage with anyone else.

The HealthData@EU Pilot project³ provides guidelines for data quality, data transfer and data security to establish a cross-border infrastructure for research projects using health data from various EU states. The project provides valuable insights that can be used as a basis to extend existing ontologies when health data is used. In our work, we introduce an ontology and a contract structure for sharing health data in the context of IDS RAM. These can be extended in the context of this project or similar projects.

3 Background on IDS RAM

The IDS introduced a reference architecture for data spaces [1]. The goal is to share data between many parties while preserving data sovereignty and security. The architecture is structured into five layers: The business layer that deals with the participants in a data space, the functional layer that defines the goals, the process layer that defines the data flows, the information layer that provides a model of data, and the system layer that presents the technical details of a data space. The main goal is to establish a trusted network of participants that can share their data. Each participant can make data available and define policies of what the data can be processed for, how and by whom it can be used. The participants negotiate contracts to ensure the conditions of data sharing. Data is made public by offering metadata in a broker, which has a catalog of data that can be shared. A data exchange is enabled by connectors. A connector is a software that communicates with the connectors of other participants to enable data exchange.

Figure 1 introduces the roles and their interactions in the IDS RAM. The following roles are introduced in the IDS RAM [1]:

- *Data Broker* has an overview of data providers and enables consumers to find appropriate providers.
- *Data owner* has control over the data and makes policies of how to use the data.
- *Data provider* provides an overview of the data to the broker and negotiates contracts based on the owner's policies with the data consumer.
- *Data consumer* is the counterpart to the provider. It searches for data in the broker's catalog and requests it from the provider after a contract has been created.

³<https://ehds2pilot.eu/project/>

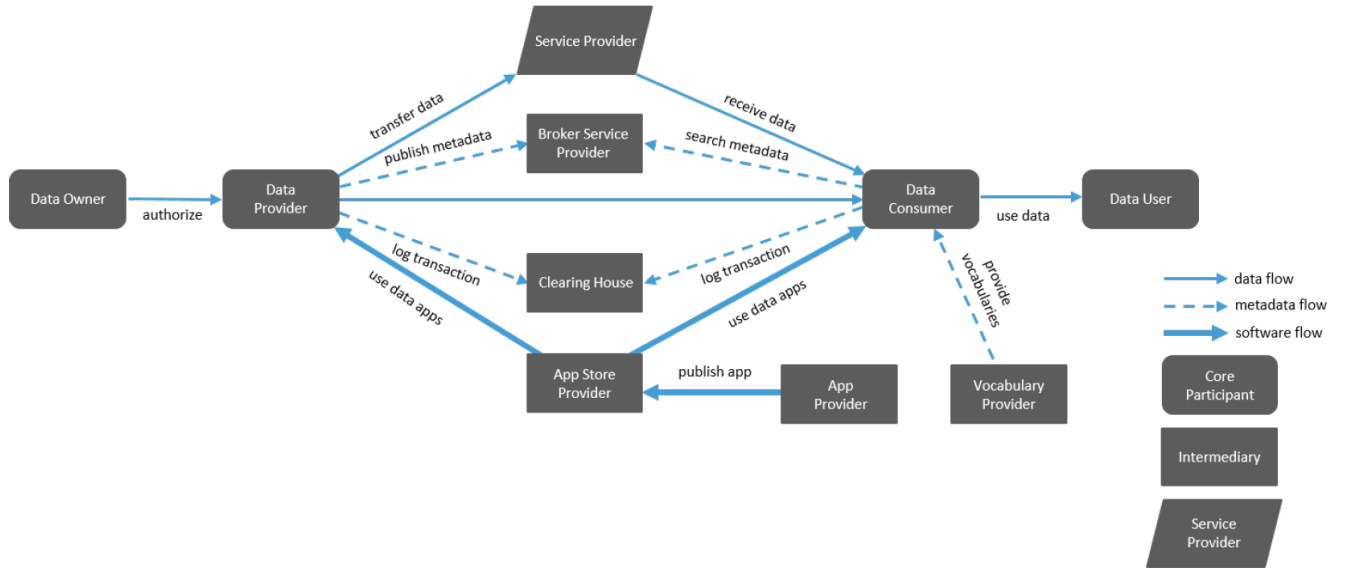


Figure 1: Basic interactions for data exchange and data sharing in the IDS RAM.

- Data user ends up working with the data. They stick to the rules of the contract between a consumer and a provider.

Other elements are provided in the IDS RAM documentation [1]. In Section 5 we introduce new roles to address the privacy requirements of patients and their health data in a data space.

4 Contracts in data spaces

A contract offer refers to a proposal made by a data space participant to share a specific set of data with other data space participants [1]. Data sharing agreements (also known as usage contracts) are essential constructs in data spaces governing the terms, permissions, and constraints of data exchange between providers and consumers. Despite the existence of the IDS RAM, there is no formal or widely adopted structure for contract offers when it comes to health data in the context of data spaces. A structured contract ensures clarity by outlining the scope, purpose, responsibilities, and terms of data sharing between participants in a health data space. It establishes a framework that reduces ambiguity, mitigates potential disputes, and facilitates effective communication, thereby fostering trust and compliance among all participants involved.

IDS RAM uses a different terminology comparing to the GDPR. A data provider in the IDS RAM can be a data controller or a data subject according to the terminology of the GDPR. A data consumer can be a data controller or a data processor.

To propose a structure for contract offers, we first define an ontology that represents the domain of contracts in data spaces.

4.1 Ontology Engineering for Contract Offers

An ontology provides a common and precise language for defining the foundational terminologies used in contracts, ensuring that all parties involved share a clear and unambiguous understanding of key terms and concepts used in contracts. This allows us to mitigate potential misunderstandings and disputes, contributing to more effective and trustworthy contract negotiations [3, 11].

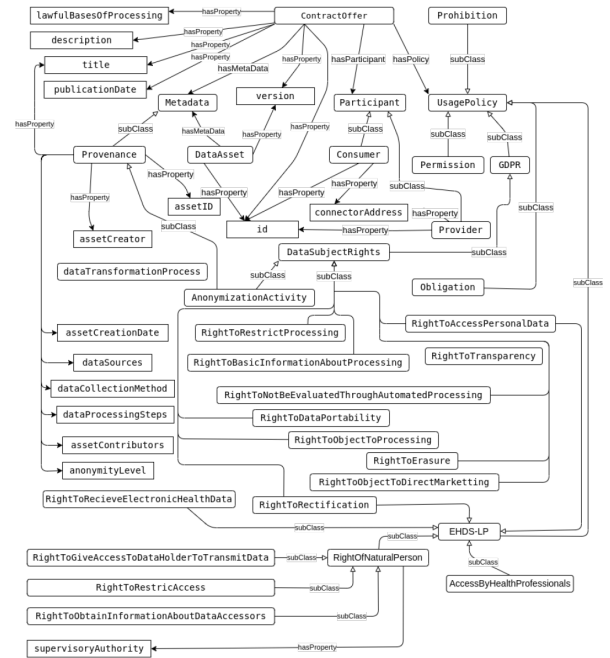


Figure 2: Ontology graph excerpt.

While the existing initiatives, including the Usage Contract Language from [23] the IDS RAM, the policy expression technique presented by Steyskal et al. [27] and the Open Digital Rights Language (ODRL) [14] offer valuable contributions to the domain of data sharing agreements in data spaces, we choose to build an ontology in the first phase of our proposed solution. In principle, ontologies are built to satisfy a predefined purpose [20]. Given this fact, we argue that any existing ontology could hardly holistically be used as the bases of the proposition of a structure for contract

offers in the context of health data spaces, because the existing related ontologies were not build for the aforementioned purpose based on our investigation of the current state of the art (Section 2). However, we use the terminology used in the abovementioned references [14, 23, 27] and other ontologies (such as GDPRtEXT [24] and PROV-O [4]) to develop our proposed ontology.

There exists a wide range of legislations on data sharing. We narrow our scope to the GDPR as it serves as the principal legislation governing the utilization of personal data within the European Union. Additionally, we also delve into the proposal for a Regulation on the European health Data Space (EHDS). We concentrate on the rights of data subjects (specified in the GDPR through Articles 13-18 and 20-22), the contractual terms required in agreements between controllers and processors (stipulated in Article 28 of the GDPR), lawfulness (stipulated in Article 6 of the GDPR), transparency, purpose limitation, accuracy, data minimisation, security (stipulated in Article 5(1)(a-f) of the GDPR), the primary use of electronic health data (Article 3 of the EHDS) and the access by health professionals to personal electronic health data (Article 4 of the EHDS).

Figure 2 depicts an excerpt of the ontology. The UsagePolicy class stands out as a pivotal entity within our ontology, assuming a critical role in encapsulating the diverse array of usage policies that govern the intricate landscape of data assets. Embedded within our comprehensive data sharing agreement ontology, this class is intricately designed to address a broad spectrum of security and privacy policies pertinent to data assets. Its significance is further emphasized by the inclusion of sub-classes derived from the GDPR, establishing a direct and nuanced alignment with key articles. Notable sub-classes such as "RightToRectification" manifest a meticulous representation of Article 16 of the GDPR, offering individuals the explicit right to rectify inaccuracies in their personal data without undue delay. In a parallel vein, the "RightToObjectToProcessing" sub-class aligns precisely with the provisions of Article 21, empowering individuals to object to the processing of their personal data under defined circumstances. Extending this nuanced approach, additional sub-classes like "RightToRestrictProcessing", "AnonymizationActivity", "RightToErasure", "RightToBasicInformationAboutProcessing" and "RightToTransparency" intricately correspond to specific articles within the GDPR.

Moreover, the UsagePolicy class extends its significance with the introduction of the EHDS as a subclass. This extension is designed to provide comprehensive support for Article 3 and 4 of the EHDS.

The ontology provides a way to define contract-related information with metadata using the *MetaData* class. It also deals with tracking the history and data provenance, including where it originated from and how it changes during its lifecycle. This inclusion of data tracking in the contract ontology improves privacy by offering transparency about the collection, processing, and sharing of personal data, giving individuals more control and the ability to make informed choices about their data. This concept is integrated into the ontology using the *Provenance* class.

The proposed ontology is built upon a widely adopted methodology introduced in [7] and is implemented in Terse RDF Triple

Language (Turtle)⁴. We present our proposed structure for contract offers which builds on this ontology in the next section.

4.2 A Contract Offer Structure for Data Spaces

An excerpt structure of the contract offers is presented in listing 1. A contract has a *unique identifier*, a *title*, a *description*, *metadata* about the contract, the parties involved (*provider* and *consumer*), as well as the *policies* under which the data is shared and a *version*. Terminologies used in the contract offer are explicitly defined in the proposed ontology. This structure offers a framework for defining contract offers while aligning with linked data principles—by using uniform resource identifiers and locators to refer to concepts. The proposed contract structure is implemented using JSON-LD⁵.

Listing 1: An excerpt of contract Structure.

```
{
  "@context": {
    "co": "http://contract.ontology#",
    "consumer": {
      "@type": "co:Consumer" },
    "contract_id": {
      "@type": "co:contractID" },
    "contract_version": {
      "@type": "co:contractVersion" },
    "data_asset": {
      "@type": "co:DataAsset" },
    "description": {
      "@type": "co:description" },
    "lawful_basis_for_sharing": {
      "@type": "xsd:string" },
    "meta_data": {
      "@type": "co:Metadata" },
    "policies": {
      "@type": "co:Policy",
      "@container": "@set" },
    "provider": {
      "@type": "co:Provider" },
    "publication_date": {
      "@type": "co:publicationDate" },
    "title": {
      "@type": "xsd:string" },
    "version": {
      "@type": "co:version" } } }
```

4.2.1 Defining contracts with the proposed contract structure. One can observe that a contract C , can be defined as a set:

$$C = \{P, CN, C_i, DA, DES, MD, T, V, \Omega\} \quad (1)$$

where P represents the data provider, CN the data consumer, C_i a unique identifier for the contract, DA the data asset, DES the data description, MD the meta data, T the title of the contract, V the version of the contract, and Ω a set of policies characterizing the data sharing between the data provider and the data consumer. For instance, let us consider two data space participants; a hospital H who wants to share its data with an insurance company I . H can draft a contract offer C by specifying the proposed structure as the

⁴Turtle serves as a serialization format for representing graphs within the Resource Description Framework (RDF).

⁵JSON-LD is a lightweight Linked Data format. It is easy for humans to read and write. It is based on the already successful JSON format and provides a way to help JSON data interoperate at Web-scale (<https://json-ld.org>).

context of their JSON-LD document. As such, C , could be described as follows:

$$C = \{H, I, C_i, DA, DES, MD, T, V, \Omega\} \quad (2)$$

where H represents the hospital (data provider—according to the GDPR, a data controller) and I the insurance company (data consumer—according to the GDPR a data processor). In this scenario a data subject is a patient to whom data belongs, however the data is gathered by the hospital which is a data controller.

Let us assume for instance that H does not want the shared data to be retained for more than 3 months. This policy fall under Article 5(1)c of the GDPR also known as *data minimisation*—where the GDPR prescribes that personal data shall not be stored for no longer that necessary for the purpose it pursues. This policy is represented using our proposed structure as follows:

Listing 2: An example of contract Structure.

```
{ "policy-class": "dataMinimization",
  "policy-properties": {
    "action": "delete",
    "constraint": [{
      "leftOperand": "duration",
      "operator": "lt",
      "rightOperand": {
        "@value": "P90D",
        "@type": "xsd:date" } } ] } }
```

It is common to have two or more conflicting policies. The proposed structure provides the field *order* that allows a data provider to rank their policies. Policies with higher ranks take precedence over policies with lower ranks in case of conflicts.

To design the ontology, we mainly focused on the data subject rights and the related principles. The ontology and the contract can be extended to cover more principles of the GDPR.

4.2.2 Negotiating contract offers. In case the Insurance wants to share data with the Hospital, a negotiation on Contract C is required. In Figure 3, the negotiation starts with the Insurance’s Connector sending a negotiation request to the Hospital. This request, which can deviate from the original Contract Offer, undergoes validation for syntax, content, and signature by the Hospital’s Connector. If approved, a contract is signed and confirmed. Any discrepancies result in rejection, ending the sequence. Once agreed upon, the Contract is stored on both IDS Connectors for future Policy Enforcement. Disagreements during the sequence lead to contract rejection, with notifications, revoked agreements, and the possibility of initiating a new negotiation sequence. After a successful negotiation, data sharing begins.

5 A privacy-aware reference architecture model

The reference architecture is an adaption of the IDS RAM [1]. The proposed architecture is split into five layers (Figure 4). Each layer is presented with a main goal. Compared to the IDS reference architecture, in our proposed reference architecture the data subject is introduced as an active role that has control over the data but is not involved in the data space. Furthermore, we realize *Privacy by Design* by embedding privacy aspects into the data flows.

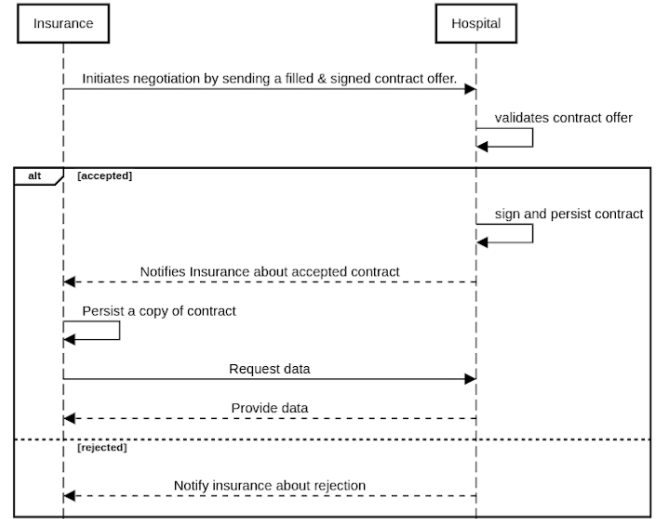


Figure 3: Contract Negotiation.

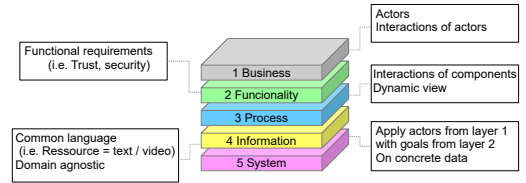


Figure 4: The overview of the layers and their goals.

5.1 Business Layer

The business layer describes the actors in a data space and their interactions.

In Section 3, we introduced several roles of the IDS RAM. In this paper, we introduce the *patient*, who is in fact the *data subject*, as an active role. Concerning the principles prescribed in the GDPR and the fact that health data is a type of personal data, a data subject has a right to deny access to, view and update their data. They give access to their records to a data owner and are informed about any sharing by the data provider. This role is not considered if no personal data is transmitted. It is the highest priority of the architecture to protect the privacy of the data subject and to not have their data linked to them after a data exchange. Data owners and data subjects are in this case distinct. A data subject may not always provide data of high quality if they are free to offer arbitrary data. If all data subjects were data owners, they could choose to make data from possibly unreliable sources available. This would lead to the need to have a validation of data on the side of the data provider to guarantee correctness, which is a challenging task in the health field. Therefore, it is better for trusted individuals or organisations like doctors and hospitals to collect data—the role *data collector*—from all of their patients and create comprehensive policies, leading to more trust in the data space.

In the proposed architecture, the provider is the entity that anonymizes the data before sending it and also offers a way for the data subjects to retract their data from the consumer. If that

happens, an updated version of the data is sent to the consumer. All policies and contracts must allow updating versions that are going to be accepted and deleting old versions on the consumer's side.

The contracts between providers and consumers are created according to the concepts introduced in Section 4. Information about what data is needed and with which granularity is needed are stored in the Metadata field. Figure 5 provides an overview of the roles in our architecture and their interactions. Comparing to Figure 1, in Figure 5 instead of *data owner* the two new roles, namely *data subject* and *data collector* are demonstrated as active roles in a data space. We consider the fact that in some scenarios the *data collector* and the *data provider* can be a same entity. For instance the data provider is a hospital which also collects data.

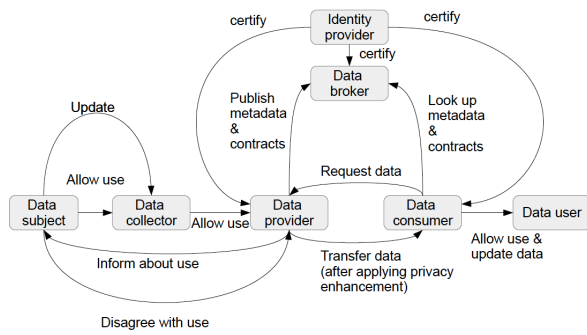


Figure 5: The overview of the business layer roles and their relationships.

5.2 Functional Layer

This layer defines the goals that the architecture has to achieve. The goals that are already mentioned by IDS RAM include security, data sovereignty, trust and standardization. Concerning our proposed reference architecture, new goals have to be considered to ensure privacy needs. It is important to prevent any party from linking a natural person to their data. To achieve the goal of privacy by design we leverage well-established privacy design strategies [13]:

-  **Minimise:** Sensitive data that is not needed should be deleted.
-  **Abstract:** Sensitive data should be only processed in the highest required granularity.
-  **Hide:** The access to sensitive data should only be granted to users with the right clearance.
-  **Separate:** The processing or storing sensitive data should occur on different locations to avoid profiling.
-  **Inform:** The person to whom the data belongs, is informed about the data processing.
-  **control:** The person to whom the data belongs has the ability to update or delete their data.
-  **Enforce:** All parties should enforce appropriate rules in their entire structure.

-  **Demonstrate:** All parties should demonstrate that they obey the rules and how they do it.

In the following section (Section 5.3) we describe how these strategies are integrated into the data flows of the IDS RAM to fully insure the privacy aspects in a data space.

5.3 Processing Layer

The process layer describes the interactions of the components in a data space. Three scenarios are covered: *Onboarding*, *exchanging data* and *updating data*. *Onboarding* remains largely the same as in the IDS RAM (a participant in the data space is introduced), *exchanging data* is adapted while *updating data* is not part of IDS.

Exchanging data involves the connector of a data provider, the connector of a data consumer, the data broker and data subjects. In this process, a focus must be put on anonymizing sensitive data before sending it and informing data subjects when a transfer has happened. The data subjects have a possibility to object to the sharing. Exchanging data includes two steps:

(I) When a consumer looks for data, they query the broker, with a set of tags. The broker publishes an overview of data in its catalog that fulfill the criteria. The consumer can find out, if the data is suitable using a same vocabulary and a common language. The information has to contain the provider, their respective description, a description of the data and the restrictions on privacy, in terms of the amount of time that data can be saved, where it can be saved, by whom it can be seen and for what purposes it can be used. Following this, the consumer chooses appropriate data.

The consumer sends a proposal of a contract (Section 4) to the provider. The provider checks this contract with own policies. If the contract is valid, the connector accepts it. If the contract is different, the connector can either still accept it (for example if more money than required is offered for otherwise unchanged conditions) or it can be refused. The provider can also make a counter offer and if the consumer accepts it, the provider send a message confirming the contract. The contract must be immutably held by both parties. According to the GDPR—Article 51—an independent public authority have to monitor the application of the GDPR. All data subjects whose data is effected by this contract must be informed that a contract has been made. They need to receive the information about the data consumer and user, the details of the contract, what data is being offered and the reason for the transfer.

(II) When a data exchange is started, the consumer asks for the data with the contract ID, that has been previously established. The provider then fetches the data and anonymizes it according to the contract. This may involve deleting data that is not needed, abstracting data, or purposefully falsifying it in order to achieve differential privacy [6]. The data subjects are informed that their data has now been transferred. This entire process can be seen in Figure 6. It is shown as a BPMN diagram [10]. As privacy is a main focus of this work, the symbols from the functional layer that represent the 8 strategies of data protection by design are used to annotate the data flow specifying where they are applied. Each pool represents an actor: *consumer*, *provider* and *data subject*. The provider has a connector, which is the piece of software that actually transfers the data and a *data Plane* that manages the data. The two

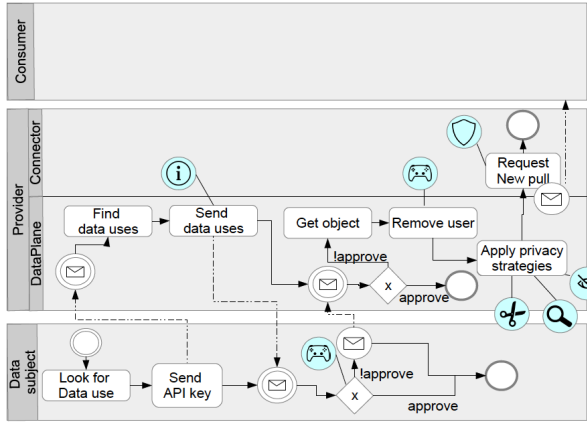


Figure 6: The data flow of a data exchange.

of them are separated as to prohibit an incriminated connector from effecting data directly.

The minimising of data is achieved by determining in the contract what data is required by the consumer and deleting everything that is not included. Abstraction can be achieved by cutting off the last digits of number values, or going up a branch for categorical data that is ordered in a tree form (i.e. abstract both the terms "dog" and "cat" to "mammal", as it is a super category for both terms). The hiding of data is done by setting sensitive data to place holders. If the data is supposed to be linked to other documents, the ID must remain static. That way the person is not associated, but multiple documents can be linked. It is vital that the connection between the ID and the person is stored at a secure location.

Updating data happens, when a data subject wants to avoid sharing data with a certain consumer. When data subjects want verify for what purpose their data is being processed, they query own data from the data provider that they are associated with. The provider then sends them the data with all associated data consumers and a short description of them. It has to be ensured that only the person who owns the data has access to them. Therefore, they must have already received a mode of accessing their data and an ability to remove their data from the data user (the role from the business layer that receives the data from the data consumer and ends up working with it). This gives data subjects control over their data. If data subject P decides not share their data from data set D with a consumer C , the provider must create an updated version data set D' to send to consumer C without the data of data subject P . Consumer C must be notified that data set D is updated and needs to be pulled again. This process is illustrated in Figure 7.

5.4 Information Layer

This layer is a domain-independent representation of the information model used in a data space. It remains mostly unchanged compared to the IDS RAM. There are three representations [1]. **Conceptual view** provides a general overview of the information model. It gives a high level overview of important concepts such as digital resources. **Declarative view** provides a normative view of the data. It includes the ontology for contracts (Introduced in

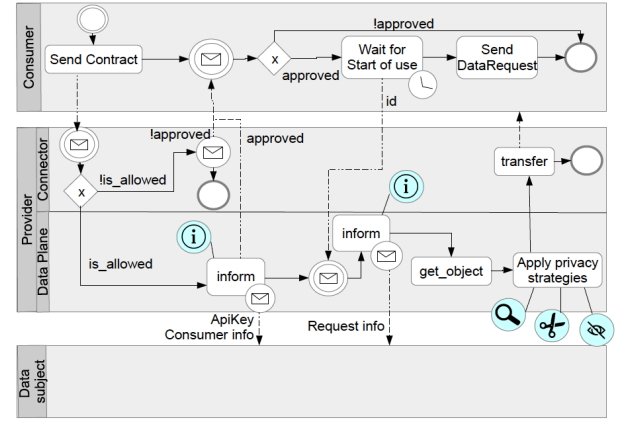


Figure 7: The updating data flow upon a data subject's request.

Section 4). In addition, an ontology for data should be used, allowing participants to be conversant with the terminologies used in the data, thus ensuring interoperability. **Programmatic view** provides an infrastructure for developers as documented libraries in common programming languages informed by the ontologies of the declarative model.

5.5 System Layer

The business layer elements have to fulfill the requirements of the functional layer and a focus is laid on the software. The connector is a software that enables communication between the data provider and the data consumer. It is further responsible for searching for a broker and exchange contract negotiations. This means that the connector is a central piece for the architecture.

The architecture of the connector is similar to the IDS RAM connector. There is a separation between the configuration model, where the system is deployed and the application management after deployment. The configuration management enables a communication between connectors, security, accessing sources for metadata and ontologies and identity management. The changes of the configuration management in the our proposed architecture compared to IDS RAM are:

- Contact information of data subjects must be stored securely in a database that the connector can access. It can be used to contact them when their data is being processed.
- A selection of anonymization algorithms must be available to be used upon the transfer of data.

Like in the IDS RAM, the application management is concerned with transferring data and negotiating contracts. It needs a data router that transfers data securely to its destination [1]. In the new proposed architecture the following features are added:

- Anonymization algorithms are being applied before a data exchange. The level of anonymization is set by the contract, but must be cross checked with the requirements of the data itself.
- Minimisation, hiding and abstraction should be applied to the data before a data exchange.

- Whenever a data subject denies a consumer access to their data, this information must be stored securely and new version of the data must be provided to the consumer.

5.6 Discussion

Our proposed reference architecture leverages the IDS RAM as a basis and adapts it to incorporate privacy and realize health data requirements. By introducing the data subject as an active role and having trusted data owners as managers of policies, trust in the data space can be ensured. The data subjects are *informed* of each exchange of their data and they are given the chance to remove data, giving them *control* over their data. Before sending the data, unnecessary information gets thrown out (*minimisation*), linking data is *hidden* behind pseudonyms, and other personal data is *abstracted*. This resolves the challenges faced by the IDS reference architecture [1].

6 Evaluation

6.1 Evaluating the Proposed Contracts

We evaluate the contract ontology and the structure of the contracts in the following two subsections.

6.1.1 Evaluating the Contract Ontology. It is quite challenging to evaluate an ontology because the provided information in an ontology is rather subjective. Quality and correctness are two important ontology evaluation perspectives [12] that address the accuracy, completeness, conciseness, adaptability, clarity, computational efficiency and consistency of an ontology [21, 30]. To evaluate the contract ontology, we use a corpus-based approach, which addresses accuracy, completeness, conciseness, clarity and consistency to a great extent [26]. According to this approach, a well-constructed ontology should accurately capture the concepts and associations prevalent in the actual language used within the domain it seeks to represent. We use two corpora; the GDPR (General Data Protection Regulation) and the proposal for a regulation on the European Health Data Space (EHDS).

Our focus will be on accuracy and coverage. For that, we define our evaluation metrics as follows:

$$Precision = TP / (TP + FP) \quad (3)$$

$$Recall = TP / (TP + FN) \quad (4)$$

$$F1 - Score = 2 * (Precision * Recall) / (Precision + Recall) \quad (5)$$

$$Coverage = \left(\frac{\#OC \in corpus}{|ontology|} \right) \quad (6)$$

Where TP is the correctly identified concepts from the ontology in the reference corpus, FP is the incorrectly identified concepts and FN are concepts not identified, $\#OC \in corpus$ specifies the count of concepts or entities from the ontology that are present in the corpus, $|corpus|$ signifies the total count of concepts or entities in the corpus, and $|ontology|$ denotes the total count of concepts in the ontology

$Precision$, $Recall$ and $F1-Score$ are widely used in information retrieval and natural language processing to evaluate the accuracy of ontology-based information extraction. The evaluation parameters are presented in Table 1. The result of this evaluation using the two corpora is summarized in Table 2.

Table 1: Contract ontology evaluation properties.

	TP	FP	FN	$\#OC \in corpus$	$ corpus $
GDPR	178	0	221	178	3826
EHDS	136	0	263	136	1344

Table 2: Contract ontology evaluation results.

	Precision	Recall	F1-Score	Coverage
GDPR	1.0	0.45	0.62	0.09
EHDS	1.0	0.34	0.51	0.07

In the context of GDPR, we achieved perfect precision (1.0), while there is a big room for improvement in terms of recall (0.45) and coverage (0.09). Likewise, with EHDS, we attained perfect precision (1.0) but observed lower recall (0.34) and coverage (0.07). The F1-Score, which strikes a balance between precision and recall, reached 0.62 for GDPR and 0.51 for EHDS. These results highlight strong precision while indicating opportunities for enhancing recall and coverage to encompass a broader spectrum of relevant concepts. The low coverage obtained from the corpus based evaluation could be an indicator of the incompleteness of the ontology and for the need to enrich the ontology with more concepts. However, we have to consider the fact that regulations covers various concepts that are not all necessarily inline with our purpose to design an ontology for the contracts.

6.1.2 A comparative evaluation of the proposed contract structure. Though the GDPR and other European legislations refrain from prescribing a specific template or structure for data sharing agreements, they require these agreements to comprehensively address fundamental data protection principles and considerations. In this section, our assessment of the proposed structure for contract offers hinges on completeness criteria with respect to the state of the art. We draw comparisons between the sections outlined in our contract proposal and the elements anticipated in data sharing agreements, as delineated by Matteucci et al. [19], as illustrated in Figure 8. Upon careful examination of the mapping, we ascertain that every component of a data sharing agreement seamlessly aligns with sections in our proposed contract structure.

Moreover, we evaluate completeness by comparing the contract structure proposed in Section 4 and the principles stipulated in the GDPR, namely Article 5 (Principles related to the processing of personal data), Article 28 (Processor), Article 32 (Security of Processing) and Article 35 (Data Protection Impact Assessment). These articles are selected because they convey structural elements. We further compare our proposed structure with the Cross-Border Data Transfer Mechanisms in the European Union (CBDTMEU)⁶. We deduce that the GDPR as well as guidelines in the CBDTMEU could be successfully represented in our proposed contract structure except Article 35 of the GDPR. This gives room for improvement.

6.2 Evaluating the Reference Architecture

To evaluate the correctness, we consider an excerpt of privacy threats in the PIA report [22]. We compare the IDS RAM to our

⁶Refers to legal frameworks, such as Standard Contractual Clauses and Binding Corporate Rules, used to ensure the lawful and secure transfer of personal data

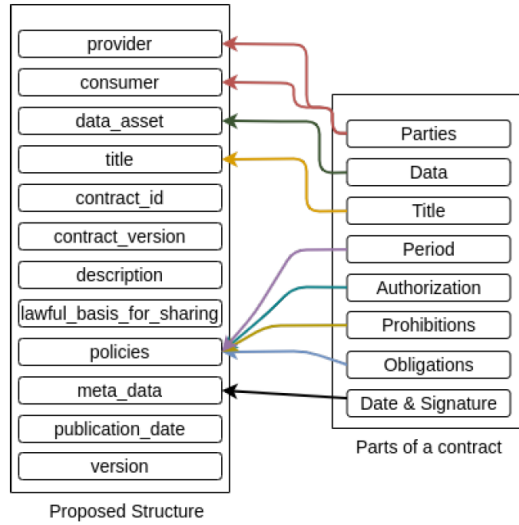


Figure 8: Mapping parts of a data sharing agreement introduced by Matteucci et al. [19] to the proposed structure for contract offers.

own by calculating the privacy risk in both architectures. The new architecture is considered correct if the threats that are not covered cannot be solved by privacy aware design and have to be mitigated by other measures. To calculate risks, the following formula is used:

$$((threat_likelihood * effect_to_data_space) + (threat_likelihood * effect_to_data_subject)) / 2 = risk_of_threat$$

The likelihood of threat is in a range between 1 and 3, with 1 being unlikely and 3 being very likely. Likewise the effect on the data space and to the data subject is between 1 and 3, with 1 being an small negative effect and 3 a large negative effect. We consider the potential effect of a threat from two points view: (I) the data subject, who aims to keep their sensitive data private and to have an understanding of happens to it. (II) the data space itself, whose reputation will suffer as a result of data leaks and which is reliant on high data quality. Table 3 provides the privacy risks.

Risks 1 and 2 are concerned with persons not being sufficiently informed of their rights and the data processing. So they do not consent to share data. This has a big effect on data subjects and less on the data space, because to a data consumer it is not apparent that an individual person does not know their rights and therefore it does not prevent data sharing. Risk 3 and 4 are concerned with the data not being handled in a private way. Risk 5 is about a lack of control from data subjects. Risk 6 is concerned with data being linkable, while risk 7 is about a lack of data quality for data users.

Our proposed reference architecture has lower risk relating to not informing data subjects that sensitive data is linked or shared. Therefore, it is easier for data subjects to understand what is happening to their data. They do not need to create policies or interact with a data space concerning freshly created data. The remaining risk for our architecture can only be remedied by obliging hospitals and doctors to inform their data subjects properly and providing

data subjects control over their data. Interacting with the data space by data sharing and stop sharing according to the data subjects' will, avoid confusion and frustration in a data space. furthermore, the level of trust for data subjects and other organisations increases. Therefore, the new architecture is an improvement comparing to the IDS RAM concerning privacy aspects in the health domain.

6.3 Application

The Eclipse Data Space Connector (EDC) [2] is used as the basis to implement the new architecture. We consider a use case based on the digitization of sick leave notices from doctors in Germany [9]. The sick leave notices are sent via XML to the insurance company of the data subject. The data will also be stored in a data structure that is accessible by the connector and can be shared with other connectors. The structure of the program can be seen in the class diagram of Figure 9. Each data object has a privacy level that describes how sensitive its information is.

The method `inform_person_of_data_use` of the Dataplane API in Figure 9 sends a mail to data subject, whenever their data is contained in a new contract or is being transferred. This fulfills the privacy design strategy *inform*. If a data subject wants to no longer share their data with a consumer, they can access the `remove_user` method via a website. The method creates a new version of the data that no longer contains the data subject's data. This is related to the *control* strategy. Before a transfer, the data that is not needed is removed (*minimisation*), some remaining sensitive data is hidden behind IDs (*hide*) and to other sensitive data the *abstract* strategy is applied. These are realized by the `minimise` and `abstract` methods of the Dataplane. Finally the `anonymize` applies a differential privacy algorithm to the data that enables plausible deniability to any data subject.

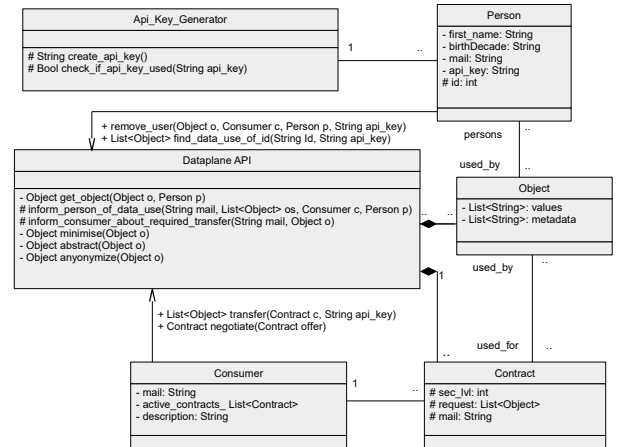


Figure 9: Class diagram of the connector in the use case.

7 Conclusion

We introduced data sharing contracts and a privacy-aware reference architecture. Ensuring privacy in a health data space is crucial, leads to more trust in the data space and reduces the risks to individuals.

Our architecture relies on the IDS RAM and aims to include privacy in all layers. We introduced the new role *patient* as an

Table 3: Risk comparison of the IDs architecture and our new architecture. The two columns named by chance show the likelihood of the threat materializing in each architecture.

Nr	Threat	Effect on data space	Effect on data subject	Chance IDS	Risk IDS	Chance new	Risk new
1	Data subject is insufficiently informed by data collection	3	3	1	6	1	3
2	No consent has been given to the transfer	2	3	2	5	1	2.5
3	Data used for other use cases than originally promised	3	3	1	3	1	3
4	Irrelevant data for the use case is transferred	1	3	2	4	1	2
5	Data subjects lack control over their data	2	3	2	5	1	2.5
6	Data can be linked to a person	3	3	2	6	1	3
7	Low data quality	3	1	2	4	1	2

active and explicit role, giving patients the chance to be informed and have control of their data in accordance with the GDPR.

In future work, we study mechanisms to enable patients to update their data themselves, considering their legal rights. Moreover, we investigate how statically (design time) and dynamically (run time) the principle of data minimisation can be realized. We further aim to use the specifications provided by the data space protocol⁷ developed by the IDS to enhance our ontology.

Acknowledgments

This research was partially supported by: (I) the Covid&AI project funded by Ministry of Science and Health of Rhineland-Palatinate, Germany (II) DATAMITE project funded by EU's Horizon Europe Research and Innovation program under grant agreement number 101092989 (III) PrivacyE2E project funded by German Federal Ministry of Education and Research (IV) TITAN Project funded by EU Research Executive Agency under grant number 101129822.

References

- [1] International Data Spaces Association. 2022. *IDS Reference Architecture Model Version 4.0*.
- [2] International Data Spaces Association. 2023. Eclipse Data Space Connector. <https://github.com/eclipse-edc/Connector>
- [3] S. R. Bader, J. Pullmann, C. Mader, S. Tramp, C. Quix, A. W. Müller, H. Akyürek, M. Böckmann, B. T. Imbusch, J. Lipp, S. Geisler, and C. Lange. 2020. The International Data Spaces Information Model - An Ontology for Sovereign Exchange of Digital Content. In *The Semantic Web - ISWC 2020 (Lecture Notes in Computer Science, Vol. 12507)*. Springer, 176–192. https://doi.org/10.1007/978-3-030-62466-8_12
- [4] K. Belhajjame, J. Cheney, D. Corsar, D. Garijo, S. Soiland-Reyes, S. Zednik, and J. Zhao. 2012. *PROV-O: The PROV Ontology*. Technical Report. <http://www.w3.org/TR/prov-o/>
- [5] Cloud Security Alliance. 2015. Privacy Level Agreement - Version 2.
- [6] C. Dwork. 2006. Differential Privacy. In *Automata, Languages and Programming, 33rd International Colloquium, ICALP 2006, Venice, Italy, July 10-14, 2006, Proceedings, Part II (Lecture Notes in Computer Science, Vol. 4052)*, Michele Bugliesi, Bart Preneel, Vladimiro Sassone, and Ingo Wegener (Eds.). Springer, 1–12. https://doi.org/10.1007/11787006_1
- [7] M. Fernández-López, A. Gómez-Pérez, and N. Juristo. 1997. Methontology: from ontological art towards ontological engineering. (1997).
- [8] International Organization for Standardization. 2022. *Information technology — Cloud computing and distributed platforms — Data sharing agreement (DSA) framework*. Standard.
- [9] GKV-Spitzenverband and Bundesagentur für Arbeit. 2022. Grundsätze für die Meldung der Arbeitsunfähigkeitszeiten im Rahmen des Datenaustausches. Online document. URL: https://www.gkv-datenaustausch.de/media/dokumente/arbeitgeber/eau/gemeinsame_grundsaeetze/Grundsaeetze_eAU_BA_AG.pdf
- [10] Object Management Group. 2011. Business Process Model and Notation (BPMN), Version 2.0. <http://www.omg.org/spec/BPMN/2.0>
- [11] H. Happel, W. Maalej, and S. Seedorf. 2010. Applications of Ontologies in Collaborative Software Development. In *Collaborative Software Engineering*. Springer, 109–129. https://doi.org/10.1007/978-3-642-10294-3_6
- [12] H. Hlmani and D. Stacey. 2014. Approaches, methods, metrics, measures, and subjectivity in ontology evaluation: A survey. *Semantic Web Journal* 1 (2014).
- [13] J-H Hoepman. 2018. Privacy design strategies (the little blue book). (2018).
- [14] R. Iannella. 2007. Open digital rights language (ODRL). *Open Content Licensing: Cultivating the Creative Commons* (2007).
- [15] C. Jung and J. Dörr. 2022. Data usage control. *Designing Data Spaces: The Ecosystem Approach to Competitive Advantage* (2022), 129–146.
- [16] A. Kari, T. Schurig, and M. Gersch. 2023. European Health Data Space (EHDS), Gaia-X and Health-X dataLOFT. (2023).
- [17] S. Kushwaha, S. Bahl, A. Bagha, K. Parmar, M. Javaid, A. Haleem, and R. Singh. 2020. Significant Applications of Machine Learning for COVID-19 Pandemic. *Journal of Industrial Integration and Management* 05, 04 (2020), 453–479.
- [18] J. S. Marcus, B. Martens, C. Carugati, A. Bucher, and I. Godlovitch. 2022. The European health data space. *IPOL policy department for economic, scientific and quality of life policies, European Parliament Policy Department studies* (2022).
- [19] I. Matteucci, M. Petrocchi, M. Sbodio, and L. Wiegand. 2011. A design phase for data sharing agreements. In *International Workshop on Data Privacy Management*. Springer, 25–41.
- [20] N. F. Noy and D. L. McGuinness. 2001. *Ontology Development 101: A Guide to Creating Your First Ontology*. Technical Report. <http://www.ksl.stanford.edu/people/dlm/papers/ontology-tutorial-noy-mcguinness-abstract.html>
- [21] L. Obrst, W. Ceusters, I. Mami, S. Ray, and B. Smith. 2007. The evaluation of ontologies: Toward improved semantic interoperability. *Semantic web: Revolutionizing knowledge discovery in the life sciences* (2007), 139–158.
- [22] M. Oetzel, S. Spiekermann, I. Grüning, H. Kelter, and S. Mull. 2011. Privacy impact assessment guideline for RFID applications. *German Federal Office for Information Security (BSI)* (2011).
- [23] B. Otto, M. ten Hompe, and S. Wrobel (Eds.). 2022. *Designing Data Spaces: The Ecosystem Approach to Competitive Advantage*. Springer. <https://doi.org/10.1007/978-3-030-93975-5>
- [24] H. J. Pandit, K. Fatema, D. O'Sullivan, and D. Lewis. 2018. GDPRtEXT - GDPR as a Linked Data Resource. In *The Semantic Web - 15th International Conference, ESWC 2018, Heraklion, Crete, Greece, June 3-7, 2018, Proceedings (Lecture Notes in Computer Science, Vol. 10843)*, A. Gangemi, R. Navigli, M. E. Vidal, P. Hitzler, R. Troncy, L. Hollink, A. Tordai, and M. Alam (Eds.). Springer, 481–495. https://doi.org/10.1007/978-3-319-93417-4_31
- [25] N. Papernot, P. D. McDaniel, A. Sinha, and M. P. Wellman. 2018. SoK: Security and Privacy in Machine Learning. In *2018 IEEE European Symposium on Security and Privacy*. IEEE, 399–414.
- [26] J. Raad and C. Cruz. 2015. A survey on ontology evaluation methods. In *Proceedings of the International Conference on Knowledge Engineering and Ontology Development*.
- [27] S. Steyskal and A. Polleres. 2014. Defining expressive access policies for linked data using the ODRL ontology 2.0. In *Proceedings of the 10th International Conference on Semantic Systems, SEMANTICS 2014, Leipzig, Germany, September 4-5, 2014*, H. Sack, A. Filipowska, J. Lehmann, and S. Hellmann (Eds.). ACM, 20–23. <https://doi.org/10.1145/2660517.2660530>
- [28] European Union. 2016. Regulation (EU) 2016/679 of the European Parliament and of the Council.
- [29] European Union. 2022. Proposal for a Regulation of the European Parliament and of the Council on the European Health Data Space.
- [30] D. Vrandečić. 2009. Ontology evaluation. In *Handbook on ontologies*. Springer, 293–313.

⁷<https://docs.internationaldataspaces.org/ids-knowledgebase/v/dataspace-protocol>